

安全架构规范

技术规范文件

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

目录

- 1. 概述
- 2. 安全架构原则
- 3. 数据安全分级
- 4. 应用安全规范
 - 4.1 认证与授权
 - 4.2 API 安全
 - 4.3 输入校验
- 5. 网络安全规范
- 6. 数据安全规范
 - 6.1 加密体系
 - 6.2 脱敏规则
 - 6.3 审计日志
- 7. DevSecOps 实践
- 8. 安全事件响应
 - 8.1 事件分级
 - 8.2 应急流程
- 9. 合规要求映射

安全架构规范

1. 概述

本文档定义保险技术平台的安全架构规范，涵盖网络安全、应用安全、数据安全、身份认证与权限管理、安全运营等方面。参考等保 2.0、ISO 27001、PCIDSS 等行业标准。

2. 安全架构原则

- 纵深防御：网络层、主机层、应用层、数据层多层防护
- 最小权限：按需授权，默认拒绝
- 安全左移：安全要求在开发阶段即嵌入（DevSecOps）
- 数据分类：按照敏感度对数据进行分级保护
- 持续监控：安全事件实时检测和响应
- 合规首要：满足监管合规是硬性底线

3. 数据安全分级

等级	定义	示例	保护要求
L4 绝密	泄露会造成严重法律/经济损失	客户银行卡号、密码、生物特征	加密存储+传输, 访问需审批+审计
L3 敏感	泄露会造成中等风险	身份证号、手机号、保单详情	加密存储, 业务最小授权
L2 内部	仅限内部使用	员工工号、产品费率表	内部网络隔离
L1 公开	可对外公开	产品介绍、公司地址	无特殊要求

4. 应用安全规范

4.1 认证与授权

- 统一认证：OAuth 2.0 / OIDC 协议
- SSO 单点登录：支持 SAML 2.0 / CAS
- 多因素认证：管理后台和内网系统强制 MFA
- API 鉴权：JWT Token + Scope 权限管控
- 细粒度授权：基于 RBAC / ABAC 的权限模型

4.2 API 安全

- 传输层：全站 HTTPS，TLS 1.2+
- 防篡改：请求签名（HMAC-SHA256）
- 防重放：Timestamp + Nonce 机制
- 限流：按 API Key 和应用维度
- 敏感字段：响应中自动脱敏（手机号、身份证）

4.3 输入校验

- 服务端对所有输入做参数校验和过滤

- 防注入：SQL/NoSQL/XSS/命令注入防护
- 文件上传：白名单后缀、大小限制、内容检测
- 使用 ORM + 预编译 SQL，严禁拼接 SQL

5. 网络安全规范

区域	隔离级别	访问控制
公网	Internet	WAF + CDN + Anti-DDoS
DMZ	非军事区	反向代理 + API 网关
应用网段	内网隔离	服务间 mTLS
数据网段	最高隔离	数据库白名单 + 代理访问
管理网段	堡垒机	操作审计 + 会话录像

6. 数据安全规范

6.1 加密体系

- 传输加密：全链路 TLS 1.3
- 存储加密：AES-256 静态加密
- 字段级加密：敏感数据应用层加密
- 密钥管理：集中式 KMS，定期轮转（90天）

6.2 脱敏规则

数据类型	脱敏方式	示例
手机号	中间4位隐藏	138****1234
身份证	保留前6后4	110101****1234
银行卡号	保留前4后4	6222****5678
姓名	保留姓，名用*	张**

6.3 审计日志

- 所有数据访问行为记录审计日志
- 审计日志不可篡改、不可删除
- 保留周期 ≥ 180 天
- 日志内容包括：操作人、IP、对象、操作类型、时间

7. DevSecOps 实践

阶段	安全活动	工具
需求	安全威胁建模	STRIDE
编码	代码静态扫描	SonarQube / Fortify
构建	依赖漏洞扫描	Snyk / Trivy
测试	DAST 动态扫描	OWASP ZAP
部署	容器镜像扫描	Trivy / Clair
运行	运行时监控	WAF + RASP + SIEM

8. 安全事件响应

8.1 事件分级

级别	定义	响应时间	上报路径
P0	核心服务被入侵或数据泄露	立即	CEO + 安全负责人
P1	重要系统遭攻击但数据未泄露	30min	安全负责人
P2	一般安全事件	2h	安全团队
P3	低风险告警	24h	值班人员

8.2 应急流程

□□ → □□ → □□ → □□ → □□ → □□

9. 合规要求映射

监管要求	对应安全控制	验证方式
等保 2.0 三级	以上全部规范	等保测评
个人信息保护法	数据分级+脱敏+授权管理	隐私合规评估
偿二代	数据完整性保障	内控审计
保险法	保单数据不可篡改	区块链/数字签名